Priya Pandey

Information Security Manager | GRC, Cyber Risk & Regulatory Compliance

Results-driven Information Security Professional in Governance, Risk & Compliance (GRC), Cyber Risk, and Regulatory Compliance to lead enterprise security programs, drive audit, regulatory excellence, and strengthen organizational resilience across banking and digital ecosystems. Strategic communicator and presenter with strong cross-functional leadership, adept at stakeholder liaison, risk-driven decision-making and multitasking under high-stakes environments. Committed to continuous learning, development and building a robust security culture.

✉ **priya.pn8916@gmail.com** 📱 **+91 8910947726**

Profile Summary

- **Information Security Manager** with 9+ years of experience driving enterprise-wide Governance, Risk & Compliance (GRC) programs across IT, healthcare, banking, and payment ecosystems, delivering measurable improvements in security posture and regulatory readiness.
- **Proven expertise in leading complex, multi-regulatory initiatives** spanning PCI DSS, PCI PIN, PCI P2PE, ISO 27001, ISO 42001, ISO 27017/27018, GDPR and RBI frameworks, ensuring sustained audit readiness and strengthened control maturity.
- **Strategic partner to executive leadership (CISO, CIO, CXO level)**, influencing cybersecurity strategy, risk prioritization, and compliance roadmaps through data-driven insights and governance oversight.
- **Demonstrated track record of reducing audit findings and closing control gaps**, institutionalizing risk-based security frameworks to enhance enterprise resilience.
- **Spearheaded high-impact programs** including AI Security Governance (ISO 42001), GDPR, Data Privacy (DPDPA), Third-Party Risk Management, and Business Continuity & Disaster Recovery.
- **Strong command over enterprise risk management and regulatory assessments**, with governance oversight across VAPT, application security, network security and cloud security practices.
- **Accomplished leader in driving cross-functional collaboration and security culture**, delivering large-scale compliance and risk transformation initiatives in complex environments.

Core Competencies

Information Security Governance & Cyber Risk Management	Enterprise Risk Management & Control Frameworks	Third-Party Risk Management & Vendor Security Oversight
AI Security Governance & Responsible AI Risk Management	Cybersecurity Strategy & Security Program Leadership	Payment Security & Transaction Risk Governance
Governance, Risk & Compliance (GRC) Strategy & Implementation	Data Privacy & Data Protection Governance	Regulatory Compliance and Audit Management

Certifications

- Certified Information Security Manager (CISM)
- ISO 27001:2022 Lead Auditor
- ISO 42001 Lead Implementer
- Certified Payment Industry Security Implementer (CPISI)
- CEH (Certified Ethical Hacker)
- ITIL V4 Foundation
- DPDP Certification
- Certified NIST CSF v2.0 and NIST AI RMF

Education

PGDM in Cybersecurity
Great Lakes Institute of Management **– Grade A+**

Bachelor of Computer Science – Calcutta University

Technical Skill

- **Security Frameworks:** ISO 27001, ISO 42001, ISO 22301 ISO 27017/27018, NIST CSF, PCI DSS/PIN/P2PE
- **Risk & Compliance:** ITGC, Third-Party Risk Management, Audit & Regulatory Assessments
- **Security Domains:** VAPT Oversight, Cloud Security, Network Security
- **Tools Exposure:** Archer**,** SIEM (ManageEngine), Nessus, Wireshark, Nmap
- **Platforms:** Linux, Windows, AIX
- **End Point Protection:** Symantec EPM, TrendMicro

Rewards & Recognitions

- Successfully implemented ISO 27001 and PCI DSS frameworks across multiple organizations.
- Led ISO 42001, ISO 27017, and ISO 27018 certifications in a leading bank.
- Achieved significant reduction in audit observations and improved control effectiveness.
- Recognized with “Act with Speed” award at Axis Bank (Q1 2025).
- Received Spot performance awards at Iron Systems.

Work Experience

Axis Bank | Information Security Manager | Aug 2024 – Present

- **Driving enterprise-wide cybersecurity governance and regulatory compliance strategy**, aligning with ISO 27001, ISO 42001, ISO 27017/27018, PCI DSS, PCI PIN, and multi-regulatory mandates including RBI, SEBI, IRDA, and UIDAI.
- **Orchestrating large-scale audit and certification programs**, significantly enhancing control maturity and systematically reducing repeat audit observations through robust remediation governance.

- **Influencing executive decision-making** by partnering with CISO, CIO, and CXO leadership to present cyber risk posture, regulatory exposure, and compliance roadmaps.
- **Architecting and institutionalizing security control frameworks**, proactively addressing compliance gaps and strengthening enterprise risk posture.
- **Providing strategic oversight on internal and external security assessments**, ensuring continuous audit readiness and regulatory adherence across business units.
- **Governing enterprise security policies, standards, and regulatory documentation**, ensuring alignment with evolving compliance and risk requirements.
- **Championing organization-wide security awareness and culture transformation**, embedding risk-conscious practices across business and technology functions.
- **Leading cross-functional teams and complex engagements**, ensuring seamless execution of concurrent regulatory, audit, and security initiatives.
- **Driving enterprise cyber risk quantification and reporting frameworks**, enabling risk-based prioritization and data-driven executive decision-making.
- **Leading third-party risk governance and vendor security programs**, strengthening supply chain security and regulatory compliance.
- **Spearheading AI security governance initiatives (ISO 42001)**, establishing controls for emerging technology risks and responsible AI adoption.

National Payments Corporation of India (NPCI) | Senior Associate – Information Security | Jun 2023 – Aug 2024

- **Executed enterprise-wide ISMS maturity assessments**, identifying control deficiencies and driving structured remediation to elevate security posture.
- **Led internal and external audits across critical payment systems**, aligned with ISO 27001, ISO 27701, NIST CSF 2.0, ISO 22301, and PCI DSS frameworks.
- **Delivered executive-level reporting on security posture, audit findings, and risk exposure**, enabling governance oversight and informed decision-making.
- **Strengthened policy and control governance**, ensuring consistency, compliance, and effective implementation across business functions.
- **Managed third-party risk assessments**, mitigating high-risk vendor exposures and reinforcing ecosystem security.
- **Led Business Continuity and Disaster Recovery programs**, ensuring resilience and operational continuity.
- **Operationalized DPDPA-aligned data privacy controls**, safeguarding sensitive personal and financial data.
- **Enhanced incident response governance and crisis management capabilities**, ensuring preparedness for high-impact security events.
- **Embedded security-by-design principles across digital transformation and cloud initiatives**, aligning security with business innovation.

Intelliswift Software | Senior Associate – Audit & Compliance | May 2022– May 2023

- **Established and scaled ISMS frameworks** aligned with ISO 27001, GDPR, SOC 2, and ITGC controls across diverse product environments.
- **Directed external certification audits**, ensuring timely closure of non-conformities and sustained compliance posture.
- **Executed enterprise risk assessments**, developing comprehensive risk registers and mitigation strategies.
- **Led third-party security governance and compliance evaluations**, strengthening vendor risk management.
- **Designed and delivered enterprise-wide security awareness programs**, driving measurable improvements in compliance culture.
- **Implemented advanced security controls (WAF, NIPS, cryptography)** to strengthen data protection across environments.
- **Collaborated on Business Continuity and Disaster Recovery strategies**, ensuring preparedness and resilience.

Iron Systems Inc. Global | Team Lead – GRC | Oct 2019 – May 2022

- **Developed and implemented information security policies, procedures and guidelines** in compliance with industry standards and regulations
- **Led enterprise ISO 27001 internal and external audit programs**, ensuring adherence to global security standards and regulatory requirements.
- **Conducted Data Privacy Impact Assessments (DPIA), GDPR and Business Impact Assessments (BIA)** to proactively identify and mitigate risks.
- **Managed comprehensive IT audit engagements**, covering cloud security, data protection, access management, and governance controls.
- **Performed risk and vulnerability assessments**, delivering actionable insights to mitigate enterprise security risks.
- **Collaborated with cross functional teams** to enhance data protection and privacy measures.
- **Budget forecasting** for various information security initiatives.

Fuzzy Spark Pvt. Ltd. | Associate Executive | Jun 2017 – Oct 2019

- **Executed internal audit programs,** ensuring timely closure of non-conformities and sustained compliance adherence.
- **Strengthened governance frameworks** aligned with client, regulatory, and organizational requirements.
- **Performed complex IT Risk Assessments, Vulnerability Assessments,** Entity Level Controls Assessments. Implemented controls and Processes for Business-Critical Application based on ISO 27001, ITIL Methodology.
- **Trained employees on compliance policies and procedures**, fostering a strong culture of security and compliance.
- **Coordination of the implementation of all IT Managing service / Help desk** (Inventory like Asset Management, SLA's and OLA's, Operation's Manuals, Weekly, Monthly Incident Reports and Dash Boards.